

JuElCo Cybersecurity Resilience Program

Business Continuity Plan | Incident Response Plan | Disaster Recovery
Plan | Updated Policy

Prepared for:
JuElCo Board of Directors and Executive Leadership

Prepared by:
GridGuard Resilience Partners

May 30, 2026

Confidential – Not for external distribution without written consent

Contents

1	Business Continuity Plan (BCP)	4
1.1	Overarching Risk Analysis and Methodology	4
1.2	Business Impact Analysis (BIA)	5
1.3	Recovery Metrics: RTO, RPO, and MTD	6
1.4	Risk Analysis Using NIST SP 800-30	6
1.5	Security Control Evaluations & Improvement Recommendations	8
1.6	Resilience Strategies and Operational Continuity	9
1.7	Testing, Training, and Maintenance of the BCP	9
2	Incident Response Plan (IRP)	11
2.1	Incident Classification and Severity	11
2.2	Incident Response Roles, Responsibilities, and CSIRT Structure	12
2.3	Response Procedures: Ransomware Scenario	12
2.3.1	Scenario A: Ransomware on IT Network (e.g., SAP or Workday)	12
2.3.2	Scenario B: Suspicious SCADA Activity (e.g., Unauthorised Parameter Change)	13
2.3.3	Scenario C: Phishing with Credential Theft	13
2.4	Notification and Escalation Procedures	14
2.5	Phased Response Procedures	14
2.6	Continuous Improvement and Post-Incident Activity	15
2.7	Plan Maintenance and Testing	15
3	Disaster Recovery Plan (DRP)	17
3.1	Data Recovery Mechanisms	17
3.2	IT/OT Infrastructure Recovery Strategies	17
3.3	Backup Policy and Data Management	18
3.4	Emergency Communication Strategy	18
3.5	Testing and Maintenance Procedures	19
4	Conclusion and Recommendations	20
	Appendix A: Updated Cybersecurity Policy	22

Executive Summary

JuElCo, despite its advanced renewable energy portfolio and critical role in Sweden’s energy infrastructure, operates with a fragile and fragmented cybersecurity posture. The 2020 merger of four entities — Juteborgs Energi AB, Sundström Solar AB, NordVind Energy, and Bergköping Hydro AB — created a patchwork of legacy operational technology systems, inconsistent security policies, and undocumented workarounds. While no major cyber incident has occurred to date, the company remains highly vulnerable to ransomware, insider threats, supply chain attacks, and SCADA compromises.

The key findings of our assessment are as follows. First, JuElCo has no formal incident response or disaster recovery plans. Staff rely on personal knowledge and informal procedures rather than structured, tested frameworks. Second, access controls are dangerously weak. Shared credentials, default passwords on operational technology devices, and lack of multi-factor authentication on legacy systems are widespread. Third, there is no network segmentation between information technology and operational technology networks. This means that ransomware affecting the corporate network could easily spread into industrial control systems, potentially shutting down district heating or electricity generation. Fourth, the existing information security policy written in 2021 and removed from the web — is outdated, not enforced, and does not reflect actual practices. Fifth, security monitoring tools such as Splunk Enterprise Security are underutilized, with no operational technology logs being ingested. Sixth, backups are stored in a single physical location adjacent to the hydroelectric plant, creating a critical single point of failure. Finally, management has historically viewed cyber security as a cost rather than an investment, despite repeated warnings from the IT department.

Plan Summaries

The table below summarises the three core plans developed for JuElCo.

Table 1: Overview of Resilience Plans

Plan	Purpose	Key Actions
Business Continuity Plan (BCP)	Ensure essential operations continue during disruption	Business Impact Analysis identifies district heating and hydro as critical; Recovery Time Objectives of 2–4 hours for core SCADA; documented manual override procedures.
Incident Response Plan (IRP)	Respond to cyber incidents such as ransomware, phishing, and insider threats	Four incident levels; dedicated CSIRT; containment-first approach for operational technology; legal and regulatory escalation per NIS2.
Disaster Recovery Plan (DRP)	Recover IT and OT infrastructure after catastrophe	Restore from backups with 3-2-1 strategy; prioritise authentication services and SCADA connectivity; annual full recovery exercises.
Updated Cybersecurity Policy	Mandate security controls and governance	Appoint CISO; enforce MFA, network segmentation, annual drills; vendor security assessments; compliance with NIS2 and ISO 27001.

The GridGuard Resilience Partners recommends a phased approach to resilience improvement. In the immediate term (0–3 months), JuElCo should appoint an interim CISO, inventory all operational technology assets, change all default credentials, and isolate information technology from operational technology networks with an industrial firewall. In the short term (3–9 months), the company should implement full network segmentation, deploy operational

technology-aware security monitoring, conduct tabletop exercises, and enforce multi-factor authentication for all remote access including vendor accounts (Center for Internet Security (CIS), 2025). In the long term (9–18 months), JuElCo should replace or harden legacy programmable logic controllers that cannot support modern security, achieve ISO 27001 and IEC 62443 certification for critical facilities, and establish a 24/7 Security Operations Centre (Roussev, 2021).

By implementing these proactive resilience plans, JuElCo will align with international standards (NIST SP 800-53, CIS v8) and meet stringent European regulatory requirements, including NIS2 and GDPR (Force, 2020).

1 Business Continuity Plan (BCP)

GridGuard Resilience Partners has been formally engaged by the JuElCo Company to conduct a comprehensive overhaul of its cybersecurity operations and develop a resilient Business Continuity Plan. Our initial assessment of JuElCo reveals a fragile state of stability characterized by a "patchwork of legacy systems" integrated hastily after the 2020 merger of four separate energy providers. The current environment lacks formal documentation for disaster recovery, and the organization relies heavily on the unwritten, personal knowledge of a few veteran employees rather than structured, tested frameworks (JuElCo Cybersecurity Team, 2024). This Business Continuity Plan serves as the foundational roadmap to ensure that JuElCo can sustain its mission-essential energy and heating services during significant disruptions while transitioning the organization toward a proactive security posture.

The scope of this plan encompasses both the internal information technology business systems and the critical operational technology environments across the district heating, wind, solar, and hydroelectric divisions. We recognize that information systems are now vital elements in almost every mission-essential business process, and their availability is a fundamental requirement for regional safety and national security (Swanson et al., 2010). Consequently, this document establishes the interim measures necessary to recover system services after a disruption, including the potential relocation of operations to alternate sites or the use of manual methods when technical systems fail. By aligning these strategies with the NIST SP 800-34 standards and the CIS Critical Security Controls, we provide JuElCo with a repeatable and measurable approach to resilience (Swanson et al., 2010).

1.1 Overarching Risk Analysis and Methodology

GridGuard Resilience Partners conducted an overarching risk analysis utilizing the NIST SP 800-30 methodology to identify the primary threats and vulnerabilities facing JuElCo's mission-essential assets (Nelson et al., 2025a). Risk is fundamentally defined as a measure of the extent to which an entity is threatened by a potential circumstance or event, determined by the likelihood of occurrence and the magnitude of the resulting harm (Force, 2020). Our assessment characterized JuElCo's risk environment as high-risk due to the "loosely connected" nature of the network and the lack of critical security boundaries between corporate and production environments. This analysis considers not only adversarial threats like ransomware but also environmental hazards and human error arising from the use of legacy equipment (JuElCo Cybersecurity Team, 2024; Force, 2020).

Table 2: Risk Evaluation Matrix (Color-Coded)

Asset/System	Primary Threat	Likelihood	Impact	Risk Level
District Heating SCADA	Lateral Ransomware Pivot	High	Severe (Public Safety)	Critical
Hydro Control Systems	Physical/Cyber Sabotage	Medium	Severe (Grid Blackout)	High
SAP S/4HANA (Finance)	Targeted Data Breach	High	Moderate (Financial)	High
Wind Farm Controllers	Remote Hijacking	Medium	High (Production Loss)	Medium

The most severe threat identified is the lateral movement of ransomware from the business network into the SCADA systems that control electricity generation and district heating. Because JuElCo lacks strict network segmentation, a single compromised email account on a corporate laptop could provide an entry point for malware to spread horizontally into unmonitored industrial control systems (JuElCo Cybersecurity Team, 2024). This vulnerability is compounded by unpatched firmware on safety-critical components such as the Siemens SIPROTEC protection relays and the Vestas VMP controllers, which have been historically difficult to update due to licensing hurdles. Furthermore, the physical isolation of wind and solar farms makes them

uniquely vulnerable to physical sabotage or tampering, as these remote locations currently lack adequate on-site security personnel to detect unauthorized access in real-time (JuElCo Cybersecurity Team, 2024).

In addition to external threats, the risk analysis identified significant internal risks related to the management of identity and access. The widespread use of shared credentials and the discovery of default manufacturer passwords on remote technology devices create a high likelihood of unauthorized system manipulation. Furthermore, the presence of active "zombie" accounts belonging to terminated employees in the Workday and Salesforce systems presents a major insider threat and a data privacy liability under GDPR. These vulnerabilities, when combined with the lack of active security monitoring for OT logs, create a scenario where an attacker could maintain persistent access to the grid infrastructure for months without detection (JuElCo Cybersecurity Team, 2024).

1.2 Business Impact Analysis (BIA)

The Business Impact Analysis (BIA) serves as the critical second step in the contingency planning process, enabling GridGuard Resilience Partners to fully characterize JuElCo's system components and their supporting business processes. The purpose of the BIA is to correlate specific information systems with the critical missions they support and, based on that information, determine the consequences of a disruption to stakeholders. For JuElCo, the BIA focuses on determining recovery criticality by evaluating the impact on public safety, environmental health, and regional economic stability. This process is essential because it provides the justification for selecting specific recovery methods and setting priorities for the restoration of system resources (Swanson et al., 2010).

Table 3: Mission-Essential Function (MEF) Impact Analysis

Mission Process	Supporting System(s)	Dependencies	Impact of Outage
District Heating	ABB SCADA, Siemens PCS7	Biomass Supply, IT Authentication	Public health crisis in winter; pipe freezing.
Grid Stability	Hydro SCADA, GE PowerOn	Hydrological Data Sources	Regional blackout; environmental flooding.
Financial Op.	SAP S/4HANA, Salesforce	Azure AD, Internet Access	Loss of 1.9bn SEK turnover; vendor failure.
Workforce Mgmt.	Workday, MS 365	PII Data, Remote VPN	Legal liability under GDPR; payroll disruption.

We have identified several Mission-Essential Functions (MEFs) that JuElCo must sustain to prevent a debilitating effect on the region (Swanson et al., 2010). The highest-priority function is the distribution of district heating during the winter months, as a failure in this process represents an immediate threat to human life and could result in catastrophic damage to physical infrastructure from pipe freezing. Another primary MEF is grid stabilization managed through the hydroelectric plant, which is vital for balancing the national electricity supply. Secondary business functions include the management of financial operations through the SAP S/4HANA platform and the protection of employee payroll and personnel records within the Workday HR system (JuElCo Cybersecurity Team, 2024).

A critical component of the BIA involves identifying the resource requirements and interdependencies that support these MEFs (Swanson et al., 2010). For example, the district heating SCADA system is not an isolated asset; it depends on the Microsoft Azure Active Directory for

user authentication and the biomass supply chain for fuel. Similarly, the hydroelectric plant relies on real-time data from external hydrological stations to manage water release schedules and prevent reservoir flooding (JuElCo Cybersecurity Team, 2024). By understanding these dependencies, GridGuard Resilience Partners can ensure that the Business Continuity Plan addresses the entire ecosystem of resources—including facilities, personnel, and third-party vendors—required to resume operations quickly after an outage (Swanson et al., 2010).

1.3 Recovery Metrics: RTO, RPO, and MTD

To guide the selection of appropriate recovery technologies, the BIA establishes three primary metrics: Maximum Tolerable Downtime (MTD), Recovery Time Objective (RTO), and Recovery Point Objective (RPO) (Swanson et al., 2010). The MTD represents the total amount of time JuElCo leadership is willing to accept for a mission process outage or disruption and includes all impact considerations. For grid stabilization, the MTD is strictly set at twelve hours to align with national energy standards for primary essential functions. Determining the MTD is vital because it provides clear direction to contingency planners on the depth of detail required for recovery procedures and the necessary investment in high-availability solutions (Swanson et al., 2010).

Table 4: Recovery Time and Point Objectives

Business Unit	Critical Resource	MTD	RTO	RPO
District Heating	Siemens DCS / Pumps	8 Hours	4 Hours	1 Hour
Renewable Energy	SCADA / Controllers	12 Hours	6 Hours	4 Hours
IT/Business Ops	SAP / Workday	72 Hours	24 Hours	12 Hours
Sales & Market	Salesforce / CRM	96 Hours	48 Hours	24 Hours

The Recovery Time Objective defines the maximum amount of time a system resource can remain unavailable before it negatively impacts the mission and prevents the organization from meeting its MTD (Swanson et al., 2010). For the district heating SCADA system, we have established an RTO of four hours, requiring a rapid restoration capability that may include hot sites or mirrored systems to ensure safety during peak winter demand (JuElCo Cybersecurity Team, 2024; Swanson et al., 2010). In contrast, the financial SAP platform has a longer RTO of twenty-four hours, reflecting a lower-priority business function that can tolerate a temporary disruption without immediately threatening public safety. By balancing the cost of system inoperability against the cost of restoration resources, JuElCo can optimize its investment in resilience (Swanson et al., 2010).

The Recovery Point Objective represents the point in time to which data must be recovered after an outage, effectively measuring the maximum amount of data loss the organization can tolerate. For operational technology logs and SCADA setpoints, the RPO is set at one hour to ensure that the recovery team can restore a known, secure system state with minimal loss of situational awareness. The RPO for business systems like Salesforce is established at twelve hours, aligning with the daily backup routine currently performed by the IT department. These metrics ensure that JuElCo's recovery strategy is grounded in realistic operational requirements and provides a measurable baseline for testing and validation (Swanson et al., 2010).

1.4 Risk Analysis Using NIST SP 800-30

GridGuard Resilience Partners conducted a system-level risk analysis following the NIST SP 800-30 methodology to characterize the current threat landscape facing JuElCo (Force, 2020; Nelson et al., 2025a). This process involved identifying specific threat sources, determining existing vulnerabilities, and evaluating the likelihood and potential impact of successful exploits (Force,

2020). For the purpose of this assessment, both likelihood (the probability of a threat occurring) and impact (the magnitude of harm to operations or assets) were rated on a 1–5 scale. The resulting Risk Score is calculated as the product of these two values (Likelihood × Impact), with a maximum score of 25 representing the highest level of risk to the organization (Force, 2020).

The following analysis details the primary risks identified during our evaluation of JuElCo's IT and OT infrastructure:

1. Lateral Ransomware Movement (IT to OT) The most critical risk identified is the spread of ransomware from the corporate business network into unmonitored Industrial Control Systems (ICS). Because JuElCo currently lacks strict network segmentation, an attacker who compromises a single workstation via a phishing email could pivot horizontally into the SCADA systems managing district heating and hydroelectric generate.

Likelihood: 5 (High) – Due to the "loosely connected" network and lack of segmentation. Impact: 5 (Severe) – Could result in total energy loss during winter or grid instability. Risk Score: 25.

2. Exploitation of Outdated Firmware (Safety-Critical Relays) Safety-critical components, such as the Siemens SIPROTEC protection relays at the hydro plant and the Vestas VMP controllers at the wind farm, are currently running on unpatched firmware. These devices are intended to isolate electrical faults and protect turbines from catastrophic failure. An adversary exploiting these vulnerabilities could disable protective functions, leading to permanent equipment damage.

Likelihood: 4 (High) – Known vulnerabilities exist and licensing hurdles have historically prevented updates. Impact: 5 (Severe) – Failure of dam safety mechanisms or turbine destruction. Risk Score: 20

3. Unauthorized Access via Shared Credentials JuElCo's operational security is undermined by the widespread use of shared local logins and "notebook passwords" for OT systems. Additionally, vendor accounts at the district heating plant still utilize default manufacturer credentials. These weak access controls significantly increase the risk of unauthorized system manipulation by either a malicious insider or an external actor who gains access to a remote maintenance link.

Likelihood: 4 (High) – Credentials are static, shared, and physically recorded in unsecured notebooks. Impact: 4 (High) – Allows an attacker to manipulate water flow, blade pitch, or boiler temperatures. Risk Score: 16

4. Physical Sabotage at Remote Facilities The wind and solar farms are located in geographically isolated areas with minimal on-site security personnel. While perimeter fencing is in place, the reliance on automation means these sites are vulnerable to threat actors who could physically access control cabinets to insert malicious hardware or manually sabotage inverters and battery storage units. Likelihood: 3 (Moderate) – Facilities are remote and poorly monitored in real-time. Impact: 4 (High) – Physical destruction of hardware requires long lead times for replacement, extending downtime. Risk Score: 12

5. Supply Chain and Data Sovereignty Compromise JuElCo transmits sensitive wind turbine performance data to the SKF WindCon cloud platform for predictive maintenance. This dependency on a third-party service provider creates a data sovereignty issue, as JuElCo has no direct control over how this data is stored or protected on remote servers. A compromise of the vendor's infrastructure could allow an attacker to feed false sensor readings into JuElCo's systems.

Likelihood: 3 (Moderate) – Dependency on third-party security postures outside JuElCo's direct control. Impact: 3 (Moderate) – False sensor data could lead to incorrect adjustments or unnecessary maintenance. Risk Score: 9

Table 5: NIST SP 800-30 Risk Assessment Summary (Color-Coded)

Threat Scenario	Likelihood (1-5)	Impact (1-5)	Risk Score	Priority
Ransomware spreading IT to OT	5	5	25	Critical
Firmware Exploit (Relays/PLCs)	4	5	20	High
Credential Theft (Shared/Default)	4	4	16	High
Remote Physical Sabotage	3	4	12	Medium
Supply Chain Compromise (Cloud)	3	3	9	Medium

By quantifying these risks, GridGuard Resilience Partners has established a clear hierarchy for the implementation of security controls. The Critical risk of ransomware lateral movement necessitates the immediate prioritization of network segmentation (CIS Control 12) to isolate the business and production networks, maintain offline and immutable backups, and deploy application whitelisting on operational technology endpoints. The High risks associated with outdated firmware and weak authentication require a formalized vulnerability management program and a transition to Multi-Factor Authentication via Azure AD to eliminate the reliance on shared credentials, use a dedicated jump host with session recording, and enforce time-limited access. For phishing, conduct quarterly simulated phishing campaigns, enforce multi-factor authentication for all email accounts, and deploy advanced email filtering.

1.5 Security Control Evaluations & Improvement Recommendations

Our evaluation of JuElCo's current security controls reveals significant gaps when measured against the NIST SP 800-53 catalog and the CIS Critical Security Controls (Center for Internet Security (CIS), 2025; Force, 2020). The organization currently lacks the documented routines necessary to facilitate the effective implementation of security functions, leaving the IT department to manage security in a reactive manner. To address these deficiencies, GridGuard Resilience Partners recommends the transition from an outdated Information Security Policy to a comprehensive Cybersecurity Policy that mandates the enforcement of specific technical and administrative controls. These improvements focus on three critical areas: security operations, authentication, and secure remote access (JuElCo Cybersecurity Team, 2024).

Regarding security operations, we have found that the existing implementation of Splunk Enterprise Security is underutilized due to a lack of internal expertise and engineer resistance to monitoring OT logs (JuElCo Cybersecurity Team, 2024). We recommend the immediate implementation of Control SI-4, which requires continuous system monitoring to detect unauthorized network connections and adverse cybersecurity events (Force, 2020). JuElCo should establish a 24/7 Security Operations Center (SOC) capability, potentially through a Managed Security Service Provider (MSSP), to ingest and correlate logs from across the enterprise and provide real-time alerts for indicators of compromise (Debar, 2021; Force, 2020). This centralized monitoring will move JuElCo from a "fragile" state of hidden vulnerability to one of comprehensive situational awareness (JuElCo Cybersecurity Team, 2024; Debar, 2021).

Authentication and identity management controls must also be significantly hardened to eliminate the use of shared passwords and shared credentials recorded in unofficial notebooks. We recommend the full migration of all legacy OT logins to Microsoft Azure AD to enable centralized account management and the enforcement of the Principle of Least Privilege (PoLP) (JuElCo Cybersecurity Team, 2024). JuElCo must mandate Multi-Factor Authentication (MFA) for all administrative and remote maintenance access, ensuring that a separate device is required for authentication to reduce the likelihood of credential-based entry. Furthermore, a strict account deactivation routine must be established to ensure that "zombie" accounts are purged within twenty-four hours of an employee's termination or transfer (Force, 2020).

Secure remote access is the third priority for improvement, as current routines allow third-

party contractors to use personal and unmanaged devices to connect to critical plant systems. This practice creates unmonitored attack vectors that bypass JuElCo's centralized security controls (JuElCo Cybersecurity Team, 2024). We recommend the implementation of Control AC-19, which restricts remote access to organization-managed devices and requires the use of encrypted, authenticated VPNs. Furthermore, any remote maintenance sessions by vendors must be time-limited and monitored, with all default manufacturer credentials on turbine controllers and protection relays changed immediately (Force, 2020). These documented routines will ensure that JuElCo can effectively manage the risks introduced by its extensive reliance on external service providers (JuElCo Cybersecurity Team, 2024; Force, 2020).

1.6 Resilience Strategies and Operational Continuity

To achieve operational resilience, JuElCo must develop strategies that allow the organization to continue essential functions even while technical systems are in a degraded or debilitated state (National Institute of Standards and Technology, 2024; Swanson et al., 2010). This includes the identification of preventive controls, such as uninterruptible power supplies (UPS) and environmental sensors at the hydro plant, to reduce the frequency and impact of service disruptions (Force, 2020; Swanson et al., 2010). Furthermore, JuElCo should maintain the technical capability to operate its electricity generation in "island mode," allowing the local grid to remain functional even if the national network is compromised or unavailable. These resilience mechanisms ensure that the mission-essential functions identified in the BIA are sustained through both normal and adverse situations (Force, 2020; Nelson et al., 2025a).

A vital component of our recommended strategy is the formalization of the backup and recovery routine, leveraging JuElCo's existing offsite mountain room facility. While the technical task of daily incremental and weekly full backups is currently performed, there is no formal policy governing the offsite storage of backup media or the security of the transport process. JuElCo should implement Control CP-9, which requires the protection of backup information's confidentiality and integrity and mandates the testing of backup media to verify reliability (Swanson et al., 2010). The mountain room must be designated as a geographically separated alternate storage site to ensure that a single disaster at the hydroelectric plant does not destroy both the primary systems and the backup data (Force, 2020).

Finally, JuElCo must address the need for alternate processing sites to meet its RTOs during catastrophic events that disable the primary control facilities (Force, 2020; Swanson et al., 2010). We suggest a "Warm Site" strategy, which involves maintaining a partially equipped facility with spare PLC and SCADA hardware ready for rapid configuration. For high-impact systems, JuElCo may even consider reciprocal agreements with other regional energy providers to provide mutual backup support during emergencies. These strategies must be supported by pre-negotiated service-level agreements (SLAs) with equipment vendors to ensure priority shipment of replacement controllers when hardware is physically damaged (Swanson et al., 2010).

1.7 Testing, Training, and Maintenance of the BCP

A Business Continuity Plan is only effective if it is maintained as a living document and regularly validated through testing and exercises. JuElCo must move away from its current practice of "hoping the right people are available" by establishing a formal Test, Training, and Exercise (TT and E) program. This program should include periodic training to ensure all personnel understand their specific roles and responsibilities during a contingency activation (Swanson et al., 2010). Training should be augmented with simulated events to facilitate effective responses in high-pressure crisis situations (Force, 2020).

GridGuard Resilience Partners recommend a tiered testing schedule to validate the effectiveness of the BCP. Quarterly tabletop exercises should be conducted for the Computer Security Incident Response Team (CSIRT) to identify planning gaps and improve cross-team coordination.

Additionally, biannual functional tests should be performed to verify the restoration of critical database servers from the mountain room backup media. Once a year, a full-scale functional exercise should simulate the total loss of the district heating control center, testing the organization's ability to failover to an alternate site within the established four-hour RTO (Swanson et al., 2010).

Plan maintenance is equally important, as information systems undergo frequent changes due to technological upgrades or shifting business needs. The ISCP Coordinator must be responsible for reviewing the BCP at least annually and updating it after any (Swanson et al., 2010) significant system changes or actual disruptions to incorporate "lessons learned". This continuous monitoring process ensures that the plan remains accurate and that JuElCo's contingency measures evolve alongside the changing threat landscape (Force, 2020; Swanson et al., 2010). By committing to this cycle of testing and maintenance, JuElCo will transition from a state of fragile stability to one of sustained operational resilience (JuElCo Cybersecurity Team, 2024; National Institute of Standards and Technology, 2024).

2 Incident Response Plan (IRP)

This Incident Response Plan (IRP) is established by GridGuard Resilience Partners to provide Juteborg Electric and Heating Company (JuElCo) with a formal, structured framework for detecting, responding to, and recovering from cybersecurity incidents. As JuElCo currently operates in a "fragile state of stability" with no documented response playbooks, this plan transitions the organization from a reliance on the "unwritten knowledge" of a few veteran employees to a proactive, repeatable capability (Nelson et al., 2025a; Stringhini, 2021). The protection of JuElCo's energy infrastructure is a fundamental pillar of regional security, and an effective response process is vital to minimize service disruptions and data loss. This plan is aligned with the NIST SP 800-61r3 CSF 2.0 Community Profile, ensuring that incident handling is integrated into JuElCo's broader cybersecurity risk management activities (Stringhini, 2021).

The primary objective of this IRP is to safeguard the availability of mission-essential energy and heating services while protecting the integrity of operational data and the privacy of customer information (Cichonski et al., 2012; Nelson et al., 2025a; Stringhini, 2021). Senior management is committed to overseeing the incident response process, allocating the necessary funding for technical tools, and granting the Computer Security Incident Response Team (CSIRT) the authority to take high-impact actions, such as disconnecting compromised systems, to preserve the safety of the grid (Center for Internet Security (CIS), 2025; Cichonski et al., 2012; National Institute of Standards and Technology, 2024; Stringhini, 2021).

2.1 Incident Classification and Severity

To effectively manage limited resources, JuElCo must categorize and prioritize incidents based on their potential impact on mission-essential functions. An Event is defined as any observable occurrence in the system, such as a user login or a file access, while an Incident is a violation or imminent threat of violation of security policies. JuElCo will prioritize incidents using three primary factors: Functional Impact, Information Impact, and Recoverability Effort (Cichonski et al., 2012; Stringhini, 2021).

Functional impact measures the extent to which an incident affects JuElCo's ability to provide heating and electricity to the region. A "Critical" functional impact occurs when the incident results in a total loss of control over the district heating pumps or hydroelectric gates, posing an immediate threat to public safety and infrastructure integrity. Information impact characterizes the degree of data compromise. For example, a "Privacy Breach" involves the unauthorized exfiltration of customer personally identifiable information from the Salesforce CRM, while an "Integrity Loss" involves the unauthorized modification of SCADA setpoints or middleware configurations (Cichonski et al., 2012; Nelson et al., 2025b; Stringhini, 2021).

Recoverability effort is a calculation of the time and resources required to restore affected systems to a trusted state. In some cases, such as when sensitive proprietary data is exfiltrated and publicly posted, an incident may be classified as "Not Recoverable." In these scenarios, the CSIRT must pivot from restoration to long-term damage mitigation and forensic investigation and strategic damage control rather than immediate restoration (Cichonski et al., 2012; Stringhini, 2021).

Based on these factors, JuElCo utilizes a four-tier severity matrix. Severity Level 1 (Critical) is reserved for incidents that threaten human life or the stability of the regional energy grid, such as ransomware moving laterally into the production network. Severity Level 2 (High) involves significant data breaches or the compromise of administrative accounts that have not yet reached the OT environment. Severity Level 3 (Medium) covers localized issues, such as a malware infection on a non-critical business laptop. Severity Level 4 (Low) includes unsuccessful automated attacks or minor policy violations that do not pose an immediate risk to operations (Cichonski et al., 2012; Nelson et al., 2025b; Stringhini, 2021).

2.2 Incident Response Roles, Responsibilities, and CSIRT Structure

JuElCo shall establish a formal Computer Security Incident Response Team (CSIRT) based on a centralized model to ensure consistency across the district heating, wind, solar, and hydro divisions (Center for Internet Security (CIS), 2025; Cichonski et al., 2012; Force, 2020; Nelson et al., 2025b; Stringhini, 2021). The Incident Lead, typically a senior manager within the IT Department, is held accountable for the handling of specific incidents, coordinating the activities of technical responders, and providing status updates to the Board (Cichonski et al., 2012; Stringhini, 2021). Incident Handlers are the core technical staff responsible for verifying that an incident has occurred, collecting and analyzing forensic evidence, and implementing containment strategies to limit damage (Nelson et al., 2025a, 2025b; Stringhini, 2021). These personnel must possess critical thinking abilities and technical expertise in both IT (e.g., SAP, Salesforce) and OT (e.g., SCADA, PLCs) environments (Cichonski et al., 2012).

Beyond the technical team, incident response at JuElCo depends on the active participation of several cross-functional groups. The Legal Department must review incident response procedures to ensure compliance with the NIS2 directive and the GDPR, particularly regarding the handling of data breaches (Nelson et al., 2025a, 2025b; Stringhini, 2021). Public Affairs and Media Relations are responsible for managing communications with the general public and customers if an incident becomes visible, such as during an electricity outage or a heating disruption (Center for Internet Security (CIS), 2025; JuElCo Cybersecurity Team, 2024; Nelson et al., 2025a, 2025b; Stringhini, 2021). Human Resources may be involved if an incident is suspected to involve a malicious insider or if disciplinary actions are required following a policy violation. Finally, Asset Owners from the various production plants provide essential insights into the recovery priorities for their specific systems and must be kept informed of restoration progress (Nelson et al., 2025b; Stringhini, 2021).

2.3 Response Procedures: Ransomware Scenario

The following detailed response procedures are designed to address the specific technical vulnerabilities and operational risks identified within JuElCo's infrastructure. These playbooks transition the organization from a reliance on "unwritten knowledge" to a structured methodology based on the NIST SP 800-61r3 and CSF 2.0 frameworks (Cichonski et al., 2012; Nelson et al., 2025b). Each scenario emphasizes the critical need for rapid coordination between the CSIRT, IT personnel, and plant engineers to prevent cyber events from escalating into public safety crises (Nelson et al., 2025b).

2.3.1 Scenario A: Ransomware on IT Network (e.g., SAP or Workday)

This scenario involves a ransomware attack that has encrypted critical business systems on JuElCo's corporate network (Cichonski et al., 2012; Nelson et al., 2025b). Because JuElCo currently lacks network segmentation between IT and OT, the primary objective is to prevent the ransomware from moving laterally into the SCADA control systems for district heating and electricity generation (JuElCo Cybersecurity Team, 2024) **1, Detection and Analysis:** The incident is detected when Splunk Enterprise Security triggers alerts for anomalous file encryption patterns or when employees report an inability to access the SAP S/4HANA platform (Nelson et al., 2025b). The CSIRT must immediately perform an initial analysis to identify the "patient zero" workstation and determine if the ransomware has established communication with an external Command and Control (C2) server. Analysts must examine logs for the use of "zombie" accounts or unauthorized administrative access via outdated VPNs (Force, 2020; Nelson et al., 2025b).

2, Containment: The Incident Lead authorizes the immediate logical isolation of the affected IT VLANs to halt the spread of the infection. If there is a credible threat of the ransomware pivoting to production networks, the CSIRT may authorize a temporary physical disconnection

of the IT/OT bridge. Simultaneously, all compromised user accounts and administrative credentials must be disabled to prevent further unauthorized system manipulation (Force, 2020; Nelson et al., 2025b).

3, Eradication: Handlers must identify and eliminate the root cause of the infection, which is often a phishing email or a vulnerability in an unpatched business application. All malicious code must be removed from affected workstations and servers, and the systems must be hardened using standard secure configurations to prevent re-infection (Center for Internet Security (CIS), 2025; Force, 2020; Nelson et al., 2025b). **3, Recovery:** Technical teams will restore system data from the most recent "clean" backups stored in the mountain room facility. Restoration must follow a prioritized hierarchy, with identity management (Azure AD) and financial systems (SAP) restored first to support business continuity. Before reintegration, all restored assets must undergo integrity checks to ensure no dormant malicious logic remains (Force, 2020; Nelson et al., 2025b).

Post-Incident Activity: A Lessons Learned meeting is mandatory to determine why existing controls failed and how to improve detection signatures in Splunk. Findings will be used to update the Cybersecurity Policy and prioritize the long-term goal of network segmentation (Nelson et al., 2025b).

Internal communication must be conducted via secure, out-of-band channels, such as an encrypted messaging platform, to alert all staff of the system unavailability and provide instructions for manual workarounds (Cichonski et al., 2012; Swanson et al., 2010). From a regulatory perspective, this incident triggers the NIS2 Directive requirement to provide an initial notification to the national CERT within 24 hours of discovery, as it affects a critical infrastructure operator (Nelson et al., 2025b). If the attack targets the Workday platform, which contains employee social security numbers and salary details, the Legal Department and the Senior Agency Official for Privacy must assess the breach under GDPR to determine if a formal notification to the data protection authority and affected employees is required within 72 hours. The Public Affairs and Media Relations role is responsible for managing external communications, providing consistent status updates to customers and the media to prevent public panic regarding potential energy billing or service disruptions (Cichonski et al., 2012; Force, 2020; Nelson et al., 2025b).

2.3.2 Scenario B: Suspicious SCADA Activity (e.g., Unauthorised Parameter Change)

In this scenario, a threat actor gains unauthorized access to the Supervisory Control and Data Acquisition (SCADA) environment—potentially through a compromised third-party contractor's device—and modifies critical operational parameters, such as water release levels at the hydro plant or boiler pressures in the heating plant (JuElCo Cybersecurity Team, 2024).

Detection occurs when an operator notices an unexpected setpoint deviation or when a security alert is generated. Containment involves switching the affected system to manual mode using local control panels and disabling all remote access to the SCADA network. Analysis follows, with SCADA logs and VPN access logs being pulled and reviewed. Once the environment is stabilized, the CSIRT conducts forensic analysis of PLC memory and middleware to identify "logic bombs" or changes made using default manufacturer credentials (Force, 2020; National Institute of Standards and Technology, 2024). Eradication involves reversing all unauthorized changes and performing a mandatory reset of all shared credentials across the OT environment, while the recovery phase mandates the enforcement of Multi-Factor Authentication (MFA) for all future remote maintenance sessions (Force, 2020; National Institute of Standards and Technology, 2024).

2.3.3 Scenario C: Phishing with Credential Theft

Detection comes from either a user report or an anomalous sign-in alert from Azure Active Directory. Immediate containment involves resetting the affected user's password and revoking all active tokens and sessions. Investigation follows, checking for mailbox forwarding rules,

suspicious sent emails, and any accessed data. Remediation includes enforcing multi-factor authentication if not already in place and adding the user to a heightened monitoring group for 30 days.

2.4 Notification and Escalation Procedures

Rapid communication is vital for reducing the dwell time of an adversary within JuElCo's infrastructure (Center for Internet Security (CIS), 2025; Nelson et al., 2025b; Stringhini, 2021). The notification process begins as soon as a responder or an automated tool like Splunk detects a potential Severity 1 or 2 incident. The detecting individual must immediately alert the CSIRT via a secure, out-of-band communication channel, such as an encrypted messaging platform or a dedicated emergency phone line. This move away from JuElCo's current reliance on unofficial WhatsApp groups is necessary to protect the confidentiality of operational data during a crisis (Stringhini, 2021; Swanson et al., 2010).

The initial notification must provide a preliminary assessment of the situation, including which systems appear to be affected—such as the SAP S/4HANA financial platform or the Vestas wind turbine controllers—and the perceived nature of the threat. Following this notification, the Incident Lead determines if the situation warrants a formal activation of the Incident Response Plan. If activation occurs, a formal alert is sent to all members of the CSIRT and relevant stakeholders, including plant managers and legal counsel (Stringhini, 2021; Swanson et al., 2010).

Escalation is the process of involving higher levels of management or specialized external resources as an incident progresses. Functional escalation occurs when the internal technical team reaches the limit of its expertise, such as requiring a third-party forensic expert to analyze a zero-day exploit. Hierarchical escalation is triggered when an incident's impact reaches a predefined threshold, such as an outage that is expected to exceed the Recovery Time Objectives (RTOs) established in the Business Impact Analysis. In such cases, the CTO must notify the national CERT and local government authorities within 24 hours, as mandated by the NIS2 directive. This escalation ensures that leadership is aware of the potential for significant legal, financial, and reputational damage (Center for Internet Security (CIS), 2025; Cichonski et al., 2012; Nelson et al., 2025b; Stringhini, 2021).

2.5 Phased Response Procedures

JuElCo's response procedures follow a structured life cycle consisting of preparation, detection and analysis, containment, eradication, and recovery. Each phase is tailored to address the unique vulnerabilities of JuElCo's unsegmented network and legacy equipment (Nelson et al., 2025b; Stringhini, 2021).

The preparation phase is a continuous activity focused on building JuElCo's readiness. This involves the deployment of essential tools, such as forensic workstations and "Jump Kits" containing clean operating system images and spare hardware components. Preparation also includes the development of an accurate asset inventory, as it is impossible to defend systems that are not formally tracked. Furthermore, JuElCo must provide mandatory cybersecurity literacy training to all staff, focusing on the social engineering techniques that often serve as the entry point for ransomware (Cichonski et al., 2012; Stringhini, 2021).

Detection and analysis involve the active monitoring of precursors and indicators. Precursors are signs that an attack may happen in the future, such as unauthorized vulnerability scans detected in system logs. Indicators are signs that an attack is currently happening, such as an alert from Splunk about anomalous file encryption or multiple failed login attempts to a SCADA interface. When an indicator is detected, the CSIRT must perform a rapid impact analysis to determine the scope of the threat. For example, they must determine if a compromise at a remote solar farm has the potential to spread through the middleware to the central grid control systems. (Cichonski et al., 2012; Stringhini, 2021).

Containment is the highest priority for Severity 1 incidents to prevent the spread of malware from the business network into the production environment. JuElCo will utilize segment isolation as its primary containment strategy, which involves physically or logically disconnecting affected VLANs. In extreme cases involving electricity generation, the CSIRT may authorize a shift to "island mode," where the plant continues local production while isolated from the national grid. Eradication follows containment and involves the complete removal of the attacker's presence. This includes deleting malicious code, disabling compromised accounts, and resetting all shared credentials recorded in unofficial notebooks. The CSIRT must also identify and patch the root cause, such as an unpatched SIPROTEC relay, to prevent a recurrence (Cichonski et al., 2012; Stringhini, 2021).

The Recover Phase involves restoring systems to a known trusted state and verifying their integrity before they are reintegrated into the production environment. This may include restoring from clean backups stored in the offsite mountain room or, in cases involving sophisticated actors, replacing hardware and re-imaging all compromised workstations (Cichonski et al., 2012; Nelson et al., 2025b; Stringhini, 2021). Recovery is conducted in a phased approach, prioritizing high-value changes that provide the greatest immediate increase in security (Cichonski et al., 2012; Stringhini, 2021).

2.6 Continuous Improvement and Post-Incident Activity

One of the most vital parts of incident response is learning from each event to improve JuElCo's overall resilience. Within days of resolving a major incident, JuElCo must hold a Lessons Learned meeting involving all stakeholders to review the effectiveness of the response, determine if documented procedures were followed, and identify gaps in existing security controls. The findings from these meetings are used to update the Cybersecurity Policy, refine detection signatures in Splunk, and update technical training programs for the CSIRT (Center for Internet Security (CIS), 2025; Cichonski et al., 2012; Debar, 2021; Nelson et al., 2025b; Stringhini, 2021).

JuElCo shall also maintain a Follow-up Report for each incident, establishing a formal chronology of events and creating a monetary estimate of the damage caused (Cichonski et al., 2012; Stringhini, 2021). This data is not only valuable for legal prosecution but also serves as objective evidence for management to justify additional investments in cybersecurity operations, such as network segmentation or 24/7 monitoring. By integrating this improvement loop, JuElCo moves from a reactive posture toward an "Adaptive" state, where its cybersecurity practices evolve continuously based on lessons learned and predictive indicators of future threats (Center for Internet Security (CIS), 2025; National Institute of Standards and Technology, 2024).

2.7 Plan Maintenance and Testing

The Plan Maintenance and Testing section is a vital component of the Incident Response Plan (IRP), ensuring the document remains a "living" roadmap that evolves with JuElCo's changing threat landscape and infrastructure (Force, 2020; Swanson et al., 2010). Currently, JuElCo relies on "unwritten" knowledge and lacks formalized drills, making the transition to structured testing a priority for moving out of its current "fragile state" (JuElCo Cybersecurity Team, 2024).

Based on the provided standards and the JuElCo case study, the maintenance and testing activities are structured as follows:

- 1. Semi-Annual Tabletop Exercises** Tabletop exercises are discussion-based simulations conducted in an informal, stress-free environment. Frequency: Conducting these every six months (bi-annually) aligns with NIST guidelines for repeating tasks when significant changes occur or at organization-defined intervals to maintain a state of readiness. Scope: These sessions involve all response team members (CSIRT) and key stakeholders from legal, HR, and public relations to walk through specific scenarios, such as a ransomware pivot into the district heating SCADA. Objective: The goal is to validate decision-making processes, test communication chan-

nels (like call trees), and identify planning gaps without deploying actual equipment or resources (Center for Internet Security (CIS), 2025; Swanson et al., 2010).

2. Annual Full Simulation with OT Systems A full simulation, or full-scale functional exercise, is the most rigorous form of testing and involves executing roles and responsibilities in a simulated operational environment. OT Focus: For JuElCo, this simulation must specifically include Operational Technology (OT) systems to validate the "manual overrides" and restoration procedures for critical assets like the Siemens PCS7 or hydroelectric relays. Controlled Shutdown/Recovery: The simulation should include a full recovery and reconstitution of information systems to a known state, ensuring staff are familiar with alternate facilities if the primary site is compromised. Risk Mitigation: Because testing OT systems can be disruptive, NIST recommends that several smaller functional tests (like restoring a single server from backup) be conducted and evaluated before attempting a full-scale failover (Force, 2020; Swanson et al., 2010).

3. Dynamic Plan Updates The IRP must not remain static; it requires regular updates to remain accurate and effective. Post-Incident Updates: The plan must be revised immediately following any major incident to incorporate "lessons learned" from follow-up reports and meetings (Cichonski et al., 2012; Nelson et al., 2025b; Swanson et al., 2010). This process identifies deficiencies in existing controls and procedures that may have inhibited recovery. Infrastructure Changes: Any significant change to IT or OT infrastructure—such as the ongoing migration to Azure AD, the integration of new SCADA middleware, or a merger/acquisition—triggers a mandatory review and update of the IRP (Center for Internet Security (CIS), 2025; Force, 2020; Swanson et al., 2010). Annual Review: At a minimum, the entire plan should be reviewed for accuracy and completeness annually, even in the absence of major incidents or changes (Cichonski et al., 2012; Force, 2020; Swanson et al., 2010).

By formalising these procedures, JuElCo transitions from a reactive and "fragile" state into a proactive, resilient organization. This Incident Response Plan provides the technical and administrative roadmap necessary to defend the region's energy infrastructure against an increasingly sophisticated threat landscape, ensuring that JuElCo remains a reliable provider of mission-essential service.

This transition is anchored in the move away from JuElCo's historical reliance on the "unwritten knowledge" of a few veteran employees toward a mature Adaptive state of cybersecurity governance (National Institute of Standards and Technology, 2024). A formalised Incident Response Plan (IRP) directly addresses the "patchwork of legacy systems" by implementing the NIST CSF 2.0 life cycle (Detect, Respond, Recover), ensuring that responses are systematic, repeatable, and measurable rather than ad hoc (Cichonski et al., 2012; Nelson et al., 2025b). On a technical level, this roadmap provides the impetus for fully operationalizing Splunk Enterprise Security beyond simple business IT monitoring. By ingesting and correlating logs from the previously unmonitored SCADA and PLC environments, JuElCo gains the situational awareness needed to detect precursors—such as unauthorized vulnerability scans or "zombie" account activity—before they escalate into service-disrupting incidents (Force, 2020). This proactive detection is vital for defending safety-critical assets like the Siemens PCS7 and protection relays, where rapid response is the only measure preventing physical equipment failure or catastrophic infrastructure damage (Cichonski et al., 2012).

Administratively, the IRP serves as the foundation for a formal Computer Security Incident Response Team (CSIRT), providing a centralized model that standardizes security protocols across the disparate heating, wind, solar, and hydro divisions (Cichonski et al., 2012; Debar, 2021). This structure replaces unmanaged routines with secure, out-of-band communication playbooks and defined escalation paths to senior management, ensuring that "disaster recovery" no longer means simply "hoping the right people are available" when something goes wrong (Cichonski et al., 2012).

3 Disaster Recovery Plan (DRP)

The Disaster Recovery Plan (DRP) serves as the technical roadmap for restoring JuElCo's information technology (IT) and operational technology (OT) infrastructure following a catastrophic event, such as a large-scale cyberattack or a natural disaster. While the Business Continuity Plan focuses on sustaining JuElCo's mission-essential functions, the DRP provides the specific technical procedures required to reconstitute systems, networks, and data sets (Swanson et al., 2010).

This plan is specifically designed to address the recovery of JuElCo's critical SCADA environments, its financial SAP S/4HANA systems, and the underlying network infrastructure that supports the renewable and heating divisions. By aligning these strategies with the NIST SP 800-34 standards, GridGuard Resilience Partners ensures that JuElCo can meet its Recovery Time Objectives (RTO) and restore operational stability with minimal delay (Swanson et al., 2010).

3.1 Data Recovery Mechanisms

The data recovery mechanism for JuElCo is built upon a rigorous backup policy that mandates daily incremental and weekly full backups of all mission-critical data (Swanson et al., 2010). This includes not only the SQL databases supporting SAP and Salesforce but also the proprietary configurations and middleware setpoints for the Siemens and ABB control systems (Force, 2020). All backup information must be protected for confidentiality, integrity, and availability during transit to the mountain room, utilizing encrypted storage media and secure transport protocols as recommended in NIST SP 800-53 Control CP-9 (Force, 2020; Swanson et al., 2010). To mitigate the risk of a "single point of failure" at the hydroelectric plant location, JuElCo should explore a secondary cloud-based backup tier for non-sensitive business data, providing a geographically diverse recovery option that is not susceptible to the same regional environmental threats as the mountain room (Center for Internet Security (CIS), 2025; Force, 2020).

3.2 IT/OT Infrastructure Recovery Strategies

JuElCo's IT infrastructure recovery strategy is predicated on a tiered restoration hierarchy that prioritizes core services required for the broader network to function. The first priority in any technical recovery operation is the restoration of identity and access management services, specifically the Microsoft Azure Active Directory (Azure AD), which serves as the centralized authentication pillar for both IT and OT systems. Without a functional Azure AD, technicians cannot securely access the secondary systems required for energy production and financial management (National Institute of Standards and Technology, 2024; Swanson et al., 2010). Once authentication is established, recovery teams will prioritize the restoration of the SAP S/4HANA ERP system to ensure financial continuity, followed by the Salesforce CRM to manage customer interactions and billing. To support these objectives, JuElCo must maintain a "Warm Site" capability where partially equipped office space and pre-configured servers are available to resume operations within 24 to 48 hours of a disaster declaration (Swanson et al., 2010).

For the Operational Technology environment, the recovery strategy focuses on the integrity of the Industrial Control Systems (ICS) that manage district heating, wind, solar, and hydroelectric assets. Given the critical nature of the district heating pumps during winter months, this DRP mandates a rapid restoration strategy for the Siemens PCS7 and ABB SCADA environments (JuElCo Cybersecurity Team, 2024). Because these systems often require specialized hardware, JuElCo must maintain an inventory of spare programmable logic controllers (PLCs) and protection relays, such as the Siemens SIPROTEC units, stored in fire-rated containers at an alternate location (Swanson et al., 2010). If the automated control systems are completely destroyed or rendered untrustworthy by a sophisticated cyberattack, the strategy defaults to

manual overrides. This requires that current technicians maintain high proficiency in manual operation, ensuring that the district heating plant can remain operational even while the digital infrastructure is being rebuilt (JuElCo Cybersecurity Team, 2024).

3.3 Backup Policy and Data Management

The data recovery mechanism is built upon the existing daily incremental and weekly full backup routine performed by the IT department. To achieve true resilience, this routine must be formalized under NIST SP 800-53 Control CP-9, which requires the protection of backup information's confidentiality and integrity (Force, 2020; Swanson et al., 2010). JuElCo leverages its unique mountain room facility, located adjacent to the hydroelectric plant, as its primary alternate storage site (JuElCo Cybersecurity Team, 2024). This facility must be managed as a geographically separated, secure, and environmentally controlled vault to ensure that a single regional disaster does not impact both the primary data center and the backup media. All backup media transported to the mountain room must be encrypted and uniquely labeled to facilitate rapid identification during a recovery effort (Swanson et al., 2010).

Furthermore, JuElCo must move toward an isolated instance of recovery data to protect against modern ransomware that attempts to encrypt or delete online backups and adoption of the 3-2-1 backup rule with an immutable off-site copy provides a necessary technical safeguard against the single point of failure. This involves maintaining "offline" copies of critical system configurations and turbine setpoints that are not connected to the main corporate network or move all backups to a third-party data centre entirely separate from any production facility (Center for Internet Security (CIS), 2025).

To ensure data integrity, JuElCo will implement cryptographic hashing to verify that backup data has not been modified by an adversary prior to being stored (Force, 2020; Swanson et al., 2010). The Splunk Enterprise Security system, currently used for IT log monitoring, should be integrated into the recovery process to validate that restored systems are clean of any malicious indicators of compromise before they are returned to production status (National Institute of Standards and Technology, 2024).

3.4 Emergency Communication Strategy

Effective communication is critical for the activation and execution of the DRP. JuElCo must transition away from using unsecured messaging applications like WhatsApp for sensitive operational coordination during a crisis. Instead, a formal call tree and out-of-band communication platform must be established to ensure the Management Team and the CSIRT can coordinate activities independently of the internal IT network (Force, 2020; Swanson et al., 2010).

This communication strategy must include predefined templates for notifying external stakeholders, including national regulators and the public, as required by the NIS2 Directive (Debar, 2021; Nelson et al., 2025b). A designated Crisis Communications Plan needs to provide the specific protocols for fielding media inquiries to prevent misinformation during energy outages (Nelson et al., 2025b; Swanson et al., 2010). Plan maintenance is an ongoing requirement to ensure the DRP reflects the current technical state of the organization.

As JuElCo updates its hardware, such as replacing legacy Vestas VMP controllers, the technical recovery procedures and equipment lists must be updated in the DRP appendices (Force, 2020; Swanson et al., 2010). The ISCP Coordinator is responsible for conducting an annual review of the plan, or more frequent reviews if significant changes occur to the infrastructure or organizational structure following the 2020 merger. All changes to the DRP must be documented in a record of changes and communicated to all key personnel to ensure they are operating from the most current version of the "playbook" (Center for Internet Security (CIS), 2025; Force, 2020; Swanson et al., 2010).

3.5 Testing and Maintenance Procedures

A Disaster Recovery Plan remains a theoretical document until it is validated through rigorous testing and updated to reflect the evolving technical environment. JuElCo shall implement a comprehensive Test, Training, and Exercise (TTE) program that includes quarterly functional tests of backup restoration to verify the integrity of stored media (Force, 2020; Swanson et al., 2010).

Once a year, a full-scale disaster recovery exercise must be conducted, simulating a complete failure of the central control center and testing the organization's ability to failover to the mountain room facility. These exercises are critical for identifying gaps in the restoration procedures and ensuring that the IT and OT staff can execute their recovery roles under pressure. Following every exercise or actual disaster event, the DRP must be reviewed and updated to incorporate "lessons learned," ensuring that the plan remains an accurate and effective roadmap for JuElCo's technical resilience (Force, 2020; Swanson et al., 2010).

4 Conclusion and Recommendations

The present report covered a Resilience Program prepared by GridGuard Resilience Partners for JuElCo to help address potential cyber-threats that may arise. It includes a Business Continuity Plan, an Incident Response Plan, a Disaster Recovery Plan and an Updated Cybersecurity Policy.

The initial assessment revealed that JuElCo had been operating in sensitive and complex environment since the 2020 merger characterized by a patchwork of legacy systems. This resulted in a fragile environment and in multiple weaknesses regarding their infrastructures with undocumented workarounds and a heavy reliance on the unwritten knowledge of a few employees.

Our evaluation identified critical vulnerabilities, most notably the absence of network fragmentation between Information Technology and Operational Technology, allowing potential intruders to navigate easily within systems, increasing the risk for lateral movement into life-critical SCADA systems. The existing Cybersecurity Policy from 2021 was outdated and does not reflect current practices within the company.

To move JuElCo from a reactive and vulnerable posture to one of sustained operational resilience, GridGuard Resilience Partners provides the following strategic recommendations for immediate and long-term implementation. These recommendations are aligned with the NIST Cybersecurity Framework (CSF) 2.0, NIST SP 800-53, and the CIS Critical Security Controls (Center for Internet Security (CIS), 2025; Force, 2020; Nelson et al., 2025b).

JuElCo must immediately establish a formal Computer Security Incident Response Team (CSIRT) to transition from informal support to a structured capability with defined roles for incident handling, legal counsel, and public relations (Force, 2020; Nelson et al., 2025b). The organisation should immediately abolish the use of "notebook passwords" and shared credentials by mandating Multi-Factor Authentication (MFA) for all administrative and remote maintenance access via Microsoft Azure AD (Cichonski et al., 2012; Force, 2020). Prioritising the logical and physical isolation of the District Heating and Hydroelectric SCADA networks from the corporate business network is essential to prevent the lateral spread of malware. Finally, the Board of Directors must formally approve and disseminate the updated Cybersecurity Policy, replacing the outdated 2021 Information Security Policy to ensure compliance with modern regulatory requirements like NIS2 and GDPR (Force, 2020; Nelson et al., 2025b).

In the medium term, JuElCo should fully operationalise its security monitoring by ingesting OT logs into Splunk Enterprise Security and establishing a 24/7 Security Operations Centre (SOC) capability to achieve real-time situational awareness across all energy divisions (Debar, 2021; Force, 2020). Resilience must be validated through a regular Test, Training, and Exercise (TTE) program, transitioning the Business Continuity Plan and Disaster Recovery Plan into "living documents" through semi-annual tabletop exercises and annual full-scale functional simulations (Force, 2020; Swanson et al., 2010). JuElCo must also initiate a phased replacement or hardening program for legacy Vestas and Siemens controllers that cannot support modern security protocols, ensuring all mission-essential components are running on vendor-supported firmware. To provide objective assurance to stakeholders, the organisation should pursue international ISO 27001 and IEC 62443 certifications for its critical facilities (Center for Internet Security (CIS), 2025).

The protection of JuElCo's energy infrastructure is not merely a technical requirement but a fundamental pillar of national security (Force, 2020). By shifting management's perspective from viewing cybersecurity as a cost to recognising it as a vital investment in resilience, JuElCo can ensure the continued safety and reliability of the regional energy supply in an increasingly hostile threat landscape (Center for Internet Security (CIS), 2025; Force, 2020). Transforming the unwritten knowledge of its staff into documented, tested routines will move JuElCo from its current fragile state into an Adaptive posture capable of learning from and defending against advanced adversarial behaviours (National Institute of Standards and Technology, 2024; Nelson et al., 2025b).

References

- Center for Internet Security (CIS). (2025, March). *Cis critical security controls* [Version 8.1.2, March 2025]. Version 8.1. Center for Internet Security, Inc. <https://www.cisecurity.org/controls/>
- Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012, August). *Computer security incident handling guide* [Withdrawn April 3, 2025; superseded by NIST SP 800-61r3]. <https://doi.org/10.6028/NIST.SP.800-61r2>
- JuElCo Cybersecurity Team. (2024, March). Juelco cybersecurity operations and resilience case study [Available from JuElCo corporate repository].
- Debar, H. (2021, July). *Security operations & incident management* (H. Chivers, Ed.; tech. rep.) (Reviewed by Douglas Wiemer, Magnus Almgren, Marc Dacier, and Sushil Jajodia. Crown Copyright, The National Cyber Security Centre 2021. Licensed under the Open Government Licence v3.0.). CyBOK (Cyber Security Body of Knowledge). <https://www.cybok.org/>
- Force, J. T. (2020). *Security and privacy controls for information systems and organizations* (tech. rep.). National Institute of Standards and Technology.
- National Institute of Standards and Technology. (2024, February). *The nist cybersecurity framework (csf) 2.0* [Accessed: [Insert Date Here]]. <https://doi.org/10.6028/NIST.CSWP.29>
- Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025a). Incident response recommendations and considerations for cybersecurity risk management. *NIST special publication*.
- Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025b, April). *Incident response recommendations and considerations for cybersecurity risk management: A csf 2.0 community profile* [Supersedes NIST SP 800-61r2 (August 2012)]. <https://doi.org/10.6028/NIST.SP.800-61r3>
- Roussev, V. (2021, July). *Forensics knowledge area* (H. Chivers, Ed.) [Version 1.0.1, July 2021]. Version 1.0.1. CyBOK (The Cyber Security Body of Knowledge). <https://www.cybok.org/>
- Stringhini, G. (2021, July). *Adversarial behaviours knowledge area* (A. Rashid, Ed.) [Licensed under the Open Government Licence v3.0]. Version 1.0.1. <https://www.cybok.org/>
- Swanson, M., Bowen, P., Phillips, A. W., Gallup, D., & Lynes, D. (2010). Contingency planning guide for federal information systems. *NIST special publication*, 800–34.

Appendix A: Updated Cybersecurity Policy

Effective Date:	May 31, 2026
Approved By:	JuElCo Board of Directors
Policy Owner:	Chief Information Security Officer (CISO)
Compliance Standards:	NIST SP 800-53 (Rev. 5), CIS Critical Security Controls v8.1, NIS2 Directive, GDPR

Document Distribution

Name of Document	Responsible	Approved by
Cybersecurity Policy	IT Division	JuElCo Board of Directors

Version Control

Version	Release Date	Created/Amended by	Description of change
01	31/05/2026	CISO	Update version

Section 1. Purpose

The purpose of this Cybersecurity Policy is to establish mandatory security controls, governance structures, and accountability measures to protect JuElCo's information technology (IT) and operational technology (OT) assets. This policy ensures continuity of district heating and electricity generation, protects customer and employee data, and ensures compliance with applicable Swedish and European Union regulatory requirements (Center for Internet Security (CIS), 2025; Force, 2020).

Section 2. Scope

All Users are required to comply with the policy and are bound by law to observe applicable statutory legislation. This policy applies to all departments within JuElCo, along with all JuElCo employees, and third-party workers in JuElCo.

Section 3. Cybersecurity Objectives

- 3.1.** All IT systems, including but not limited to SAP S/4HANA, Workday, Salesforce, and Microsoft 365.
- 3.2.** All OT systems, including but not limited to SCADA, PLCs, protection relays, and turbine controllers.
- 3.3.** All remote access connections, cloud services, and backup storage locations.
- 3.4.** All physical facilities, including district heating plants, hydroelectric stations, wind farms, and solar arrays.

Section 4. Roles and Responsibility

The following roles and responsibilities are established under this policy:

Role	Responsibility
Board of Directors	Approve this policy, allocate resources, and oversee compliance.
Chief Information Security Officer (CISO)	Enforce this policy, manage enterprise risk, and report incidents to the Board.
Computer Security Incident Response Team (CSIRT)	Detect, respond to, and recover from cybersecurity incidents.
Asset Owners (Plant Managers)	Implement required controls and ensure staff compliance.
All Employees	Report suspected incidents immediately and complete required training.

Section 5. Access Control

5.1 Multi-Factor Authentication (MFA)

MFA is mandatory for all remote access, all administrative accounts (IT and OT), all vendor maintenance access, and all cloud applications (including Azure AD, Office 365, and Salesforce). MFA must use a separate device, such as an authenticator application or hardware token.

5.2 Credential Management

Shared credentials and passwords recorded in unofficial notebooks are strictly prohibited. Default manufacturer passwords on any OT device, including PLCs, relays, and turbine controllers, must be changed within 48 hours of this policy's effective date. All passwords must meet complexity requirements: minimum 12 characters, including uppercase letters, lowercase letters, numbers, and symbols. Accounts belonging to terminated employees must be deactivated within 24 hours.

5.3 Principle of Least Privilege (PoLP)

Users and systems shall receive only the minimum access necessary to perform their assigned functions. Administrative privileges shall be granted only for specific time-limited tasks and revoked immediately upon completion.

Section 6. Network Segmentation

- 6.1.** IT and OT networks must be physically or logically isolated using industrial firewalls.
- 6.2.** No direct routing or lateral communication is permitted between corporate VLANs and SCADA control networks.
- 6.3.** All cross-boundary access, including data historian queries and remote maintenance, must pass through a dedicated jump host with session recording and MFA.
- 6.4.** DMZs shall be established for any required IT-OT data exchange.

Section 7. Security Monitoring

- 7.1. Splunk Enterprise Security must ingest logs from all IT servers, firewalls, and endpoints, as well as all OT firewalls, jump hosts, and PLC or SCADA syslog sources.
- 7.2. A 24/7 Security Operations Centre (SOC) capability shall be operational within 12 months, either through an internal team or a Managed Security Service Provider (MSSP).
- 7.3. Alerts for anomalous activity, including unauthorized parameter changes and repeated login failures, shall trigger CSIRT investigation within 15 minutes for critical assets.

Section 8. Backup and Recovery

- 8.1. 3-2-1 Backup Rule The following standard is mandatory: three copies of data, two different media types, and one immutable off-site copy stored at a geographic location separate from the primary data center.
- 8.2. The mountain room facility is designated as the primary off-site storage location.
- 8.3. All backups must be encrypted at rest and in transit.
- 8.4. Cryptographic hashing (SHA-256 or equivalent) shall be used to verify backup integrity prior to restoration.
- 8.5. Backup restoration tests shall occur quarterly. A full disaster recovery exercise shall occur annually.

Section 9. Incident Response

- 9.1. All cybersecurity incidents shall be reported to the CSIRT immediately via the secure out-of-band communication channel (encrypted messaging platform or dedicated phone line).
- 9.2. Incident severity levels (1 through 4) are defined in the Incident Response Plan.
- 9.3. OT-related incidents affecting grid stability or public safety shall be reported to the Swedish Civil Contingencies Agency (MSB) within 24 hours, as required by the NIS2 Directive.
- 9.4. GDPR breaches, including exfiltration of customer personally identifiable information (PII), shall be reported to the Swedish Authority for Privacy Protection (IMY) within 72 hours.

Section 10. Vendor and Supply Chain Security

- 10.1. All third-party vendors with access to JuElCo systems must sign a security addendum agreeing to comply with this policy.
- 10.2. Vendors must use organization-managed devices or dedicated jump hosts. Personal devices are prohibited.
- 10.3. All remote vendor sessions must be time-limited, actively monitored, and recorded.
- 10.4. Vendor default credentials must be changed by JuElCo before any connection is established.

Section 11. Training and Awareness

- 11.1. All employees must complete annual cybersecurity awareness training, including a phishing simulation exercise.
- 11.2. OT engineers and plant operators must complete annual OT-specific training covering safe SCADA practices and physical security at remote sites.
- 11.3. CSIRT members shall participate in semi-annual tabletop exercises simulating ransomware, phishing, and SCADA compromise scenarios.

Section 12. Compliance and Enforcement

- 12.1. Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contract.
- 12.2. The security team will verify compliance with this policy through various methods, including but not limited to periodic walk-throughs, video monitoring, business tool reports, internal and external audits, and feedback to the policy owner.
- 12.3. The CISO shall conduct quarterly compliance reviews and report findings to the Board of Directors.
- 12.4. Internal audits shall occur annually. External audits shall occur biennially for ISO 27001 and IEC 62443 certification.

Section 13. Policy Review and Maintenance

- 13.1. This policy shall be reviewed annually by the CISO and updated as necessary.
- 13.2. All updates require approval by the Board of Directors.
- 13.3. Any changes to this policy shall be communicated to all employees and relevant third parties within 14 days of approval.

Section 14. Exceptions

Any exception to this policy requires written approval from the CISO and the Board of Directors. The request for exception must include documented compensating controls and a time-limited remediation plan.

Section 15. Effective Date

This policy takes effect on May 31, 2026. All individuals and entities within the scope of Section 2 are required to comply immediately.

Signatures

Approved and adopted by the JuElCo Board of Directors this _____ day of _____, 2026.

Chair of the Board of Directors
JuElCo

Chief Information Security Officer (CISO)
JuElCo

This concludes Appendix A.